SIZMA TESTİ RAPORU

Rapor Tarihi	10/08/2026
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. SQL injection vulnerability allowing login bypass

Bu raporda PortSwigger Web Security Academy'de yer alan "SQL injection vulnerability allowing login bypass" labı ele alınmıştır.

2. Yönetici Özeti

Yapılan test sonucunda, hedef uygulamanın giriş yapma (login) özelliğinde zafiyet bulunmuştur. Bu zafiyet, saldırganın kimlik doğrulama mekanizmasını atlatarak, parola bilgisi olmadan yönetici (administrator) hesabıyla oturum açmasına olanak tanımaktadır. Zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

İlgili hedef sitede, giriş yapma fonksiyonu özelliğinde SQL injection zafiyeti tespit edilmiştir. Labın çözülmesi için SQL injection attack uygulanarak login bypass (giriş atlatma) istenmektedir.

4. Risk Seviyesi

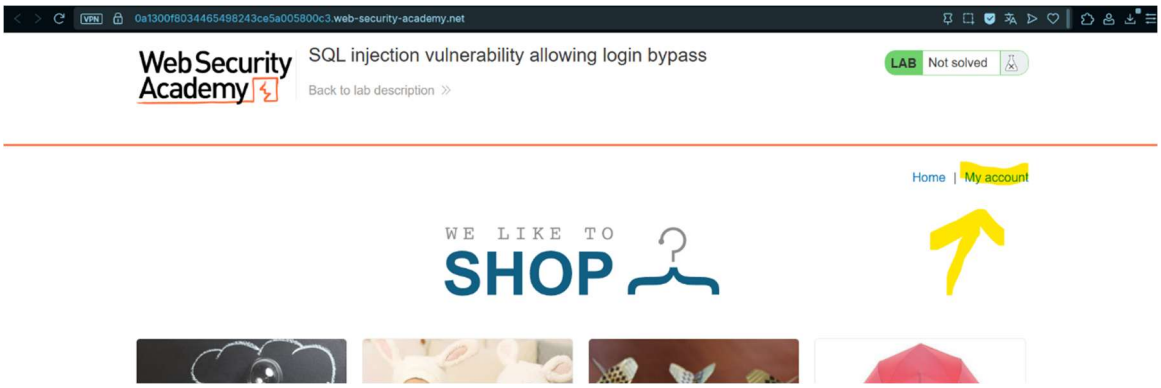
Risk Seviyesi	Kritik
CVSS v3.1 Skoru	9.4
CWE	CWE-89

5. Etki

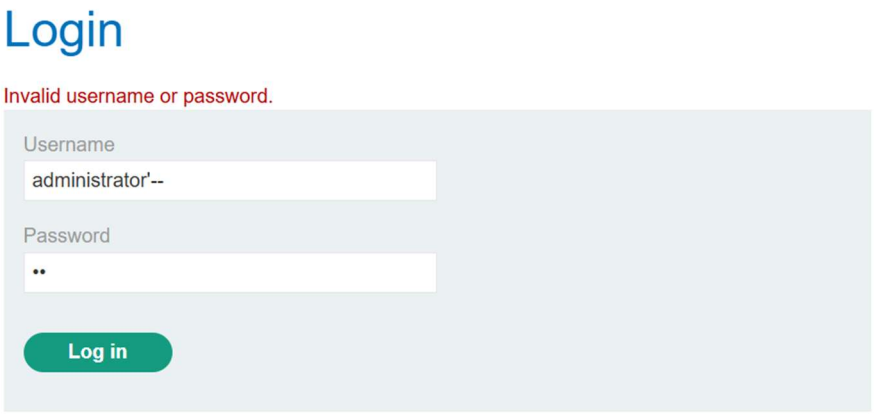
Bu zafiyetle birlikte, yetkisiz erişim ile birlikte admin (yetkili) hesabına giriş yapılabileceği tespit edilmiştir.
Aynı zafiyet, uygulamanın yetki seviyesine ve veritabanı yapılandırmasına bağlı olarak veritabanındaki tüm verilerin (kullanıcı bilgileri, parolalar vb.) ele geçirilmesine, kimlik doğrulama mekanizmasının atlatılmasına ve bazı durumlarda hedef sistemde komut çalıştırılmasına kadar ilerleyebilir.

6. Proof Of Concept

İlgili hedef siteye girildiğinde sağ üst köşede "my account" kısmı olacaktır. Buraya tıkladığımızda bizi giriş sayfasına yönlendirecektir. Burada sql injection uygulayarak giriş yapılabilmektedir.

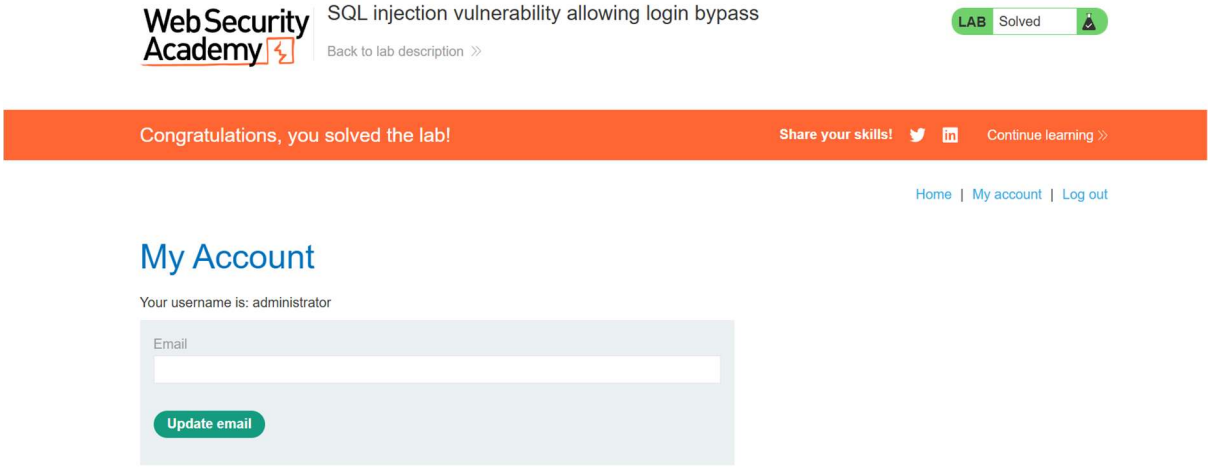


Şekil 1: My account kısmı



Şekil 2: Login kısmı

Username alanına “administrator’—“
ve password’a herhangi bir şey verildiğinde başarıyla giriş yapılabilecektir.



Şekil 3: Injection sonrası

"administrator'-- payload'ı ile kullanıcı adı string'i kapatılmakta ve -- ile sorgunun geri kalanındaki parola kontrolü yorum satırına alınarak devre dışı bırakılmaktadır. Böylece parola doğrulaması atlanmaktadır.

7. Çözüm Önerisi

Parametrik sorgular kullanılmalıdır. Kullanıcı girdisi, SQL sorgusuna doğrudan string olarak birleştirilmemelidir. Bunun yerine, sorgu yapısı ile kullanıcı verisini ayrı işleyen parametrik sorgular kullanılmalıdır. Bu sayede kullanıcı girdisi, SQL kodu olarak değil yalnızca veri olarak yorumlanır ve zafiyet kökten önlenir.

Girdi doğrulama uygulanmalıdır. Kullanıcıdan gelen veriler, beklenen türe ve formata göre doğrulanmalıdır. Kimlik doğrulama mekanizması, yalnızca SQL sorgusunun başarılı dönmesine değil, parolanın güvenli biçimde (hash karşılaştırması ile) doğrulanmasına dayanmalıdır. Parolalar veritabanında düz metin yerine güçlü bir algoritma ile hash'lenmeli ve doğrulama uygulama katmanında yapılmalıdır.

Uygulamanın kullandığı veritabanı hesabına yalnızca ihtiyaç duyduğu minimum yetkiler verilmelidir. Böylece olası bir injection durumunda etkinin (veri sızıntısı, komut çalıştırma) kapsamı sınırlandırılmalıdır.

8.Sonuç

Testin sonucunda hedefin sql enjeksiyonuna açık olduğu ve kimlik doğrulamanın atlatılarak yönetici hesabına erişilebildiği doğrulanmıştır. Zafiyet kritik seviyede olup ivedilikle giderilmelidir.
